

高安全属性价值设备威胁态势量化评估方法研究

作者：张晗洁 主题：态势感知 / 高价值设备 / 威胁量化评估

摘要

高安全属性价值设备是网络信息系统中对安全、稳定运行具有决定性影响的关键节点。传统网络安全态势评估多关注全网宏观态势，难以解释边界防火墙、核心服务、工业控制器、密码设备等关键设备在攻击过程中的具体受威胁程度。本文围绕《高安全属性价值设备威胁态势量化评估方法》展开研究性综述与分析，梳理其设备定义、指标体系、警报有效性评估、状态评估和性能修正思路，并讨论该方法在关键基础设施安全运维中的应用价值与局限。

关键词：高安全属性价值设备；威胁态势；量化评估；有效警报；性能劣化

一、研究背景与问题提出

网络安全态势感知的核心任务，是对引起安全状态变化的要素进行采集、理解、评估和预测。现有研究通常以网络整体为对象，通过探针、日志、告警、漏洞和拓扑数据形成宏观安全态势曲线。这类方法适合展示单位时间内网络总体风险变化，却不一定能解释关键设备正在承受怎样的攻击压力。原论文指出，铁路、电力、核能、金融、云数据中心和政务网络中存在一类高安全属性价值设备，例如工业控制器、边界防火墙、核心路由交换设备、网络密码设备和存储秘密信息的服务器。此类设备一旦被攻破，可能等价于关键业务域被攻破，因此需要独立的、面向设备的威胁态势量化方法。

该问题的关键在于评估粒度。宏观态势评估关注网络整体走势，容易在大规模网络中形成可视化优势；但当攻击者围绕某个边界设备、文件服务或核心控制节点进行扫描、提权、拒绝服务和横向移动时，宏观指标可能被平均化。原论文的贡献正在于把评估对象从“全网”下沉到“高安全属性价值设备”，以设备性能、配置、脆弱性、告警和状态为基础，建立更具针对性的量化框架。

二、高安全属性价值设备及指标体系

原论文首先给出了设备、安全属性价值、高安全属性价值设备、设备配置、设备警报、设备脆弱性、设备性能和设备状态等定义。其中，设备安全属性价值由保密性、完整性和可用性共同决定，并通过权重反映不同系统对三类属性的偏好。当设备安全属性价值达到给定阈值时，该设备被判定为高安全属性价值设备。这个定义具有较强现实意义，因为同样的漏洞或告警作用到不同设备上，造成的安全后果并不相同。普通终端发生异常可能只是局部事件，而边界防火墙、NFS 文件服务或核心路由设备异常，则可能影响整个业务域的可用性和安全边界。

在评估指标方面，原论文将 attrvalue、时间窗口、性能变化量、脆弱性严重程度、状态损失和状态概率结合起来。设备性能由 CPU 利用率、温度、带宽利用率、内存利用率、会话连接数和丢包率等参数刻画；脆弱性严重程度由异常严重程度和漏洞 CVSS 分值共同表示；状态概率由有效告警所反映的威胁概率给出。这样的指标体系把“设备重要性”“威胁是否有效”“设备是否劣化”和“攻击造成何种状态”放在同一量化框架中，比单纯统计告警数量更贴近攻击实际影响。

模块	原文处理方式	论文分析重点
设备价值	保密性、完整性、可用性加权计算	识别需要重点保护的高价值设备
有效警报	配置、脆弱性、性能三类证据验证	降低告警噪声，提高威胁解释力
设备状态	有效告警聚合并映射到状态区间	描述扫描、威胁、拒服等阶段
ETSA	状态概率、损失和性能劣化综合计算	形成设备级威胁态势分数

三、警报有效性与设备状态评估方法

安全运维中常见问题是告警数量庞大而有效信息有限。原论文提出的警报有效性评估算法，不是把每条告警等同处理，而是根据设备配置、设备脆弱性和设备性能三类证据进行验证。若告警涉及设备实际开放端口、服务、已知漏洞或异常，并且与性能劣化存在时间关联，则该告警更可能是真正作用于设备的有效威胁。实验中三个场景的警报约减率分别为 17.69%、33.33% 和 37.71%，平均约减率约为 33.04%，说明属性关联能够从原始告警中筛出更有解释力的威胁证据。

在状态评估方面，原论文将有效告警聚合为设备状态，并依据攻击模式建立父子状态关系。设备一般会经历正常、扫描、威胁、威胁伴随拒绝服务、达成目标等状态。不同状态对应不同的 pthreat 区间，例如 pthreat 较低时可视为正常，超过一定阈值后进入扫描或威胁状态，当 pthreat 较高且伴随性能劣化时，可被解释为拒绝服务类高危状态。该思路把告警序列从离散事件转化为可解释的状态演进，使安全人员能够理解攻击行为的发展阶段。

四、性能劣化与威胁态势量化

高安全属性价值设备的威胁态势不仅取决于告警概率，还取决于性能是否异常劣化。原论文特别讨论了性能劣化对设备态势的影响：CPU 和内存利用率异常可反映计算消耗型拒绝服务攻击，带宽利用率、会话连接数和丢包率异常可反映带宽消耗型拒绝服务攻击，设备温度异常则可能反映运行环境对设备性能的综合影响。通过性能变化累积量和影响系数 π ，方法能够把拒绝服务造成的性能压力纳入态势值。

最终的 ETSA 量化公式将状态概率、状态损失和性能劣化分量组合起来。当设备存在性能劣化时，态势值不仅包括状态概率与损失的乘积，还包括 π 对性能劣化累积量的修正；当没有性能劣化时，则主要由状态概率和状态损失决定。状态损失又由安全属性价值和脆弱性严重程度共同确定。由此可见，ETSA 不是孤立的风险分数，而是由设备价值、威胁有效性、状态演进和性能后果共同驱动的综合指标。

五、实验验证与结果分析

原论文构建了包含 DMZ、Trust、Untrust 和 Management 域的实验网络，部署 Web、MongoDB、LVS、SVN、NFS、日志服务、SFTP 和带 IPsec 功能的防火墙等资产。根据资产表，FW IPsec 设备的安全属性价值为 4.197，NFS 设备为 4.066，均超过阈值，被识别为高安全属性价值设备。实验设置了三个场景：一是边界设备暴露在互联网访问流量下，二是在互联网侧对边界设备进行扫描和拒绝服务模拟攻击，三是在内网侧对 NFS 文件服务进行扫描、提权尝试和拒绝服务攻击。

实验结果表明，警报有效性分值与设备性能变化具有一致性。例如，在远程 Telnet 提权、Syn flood 和 Udp flood 等攻击发生时，有效告警分值升高，并对应性能采样周期中的性能劣化。设备状态评估结果与实验场景也具有对应关系，在拒绝服务攻击发生时，态势量化值和安全状态等级同步升高。原论文进一步与马尔可夫、权重法、路由器专项评估和贝叶斯方法进行比较，认为该方法面向设备微观对象，普适程度较高，知识来源以概率方式为主，并支持警报约减和警报聚合。

六、方法价值、局限与改进方向

该方法的价值在于补充了宏观网络态势评估的不足。对关键基础设施而言，安全人员不仅需要知道全网风险升高，还需要知道哪台高价值设备正在被扫描、被攻击、被拒绝服务，攻击是否真正作用到了设备配置和脆弱性上，以及设备性能是否出现异常。原论文的框架能够把这些问题转化为可计算指标，有助于实现设备级预警、重点防护和运维资源调度。

不过，该方法仍有改进空间。首先，阈值区间和权重选择会影响状态判定，需要在不同业务网络中进行标定。其次，性能劣化并不总是由攻击导致，业务高峰、维护操作和硬件老化也可能造成相似曲线，因

此需要引入更细粒度的业务上下文。再次，原论文主要展示了有限实验网络中的结果，若应用到云原生、工业互联网或多租户环境，还需考虑动态资产、虚拟化迁移和跨域告警关联。未来可结合图模型、时间序列异常检测和专家规则，对有效告警关联和状态转移进行更精细建模。

七、应用场景与落地建议

从落地角度看，该方法适合部署在安全运营中心、工业控制安全监测平台、政务专网和金融数据中心的关键资产监测模块中。实践中可以先依据资产清单、业务依赖和安全属性等级筛选高价值设备，再对这些设备建立配置基线、漏洞基线、性能基线和告警基线。这样做的好处是，安全平台不必对所有资产使用同样精度的评估算法，而是把计算资源集中在真正影响业务连续性和安全边界的节点上。

在实施流程上，建议分为四步。第一，完成设备建模，明确设备类型、开放服务、IP 地址、端口、业务角色和安全属性价值。第二，接入多源数据，包括 IDS 告警、防火墙日志、漏洞扫描结果、系统性能指标和业务访问记录。第三，建立告警有效性验证规则，将原始告警与设备配置、脆弱性和性能曲线对齐，减少误报和孤立告警。第四，输出设备态势分值、状态标签和处置建议，使运维人员能够区分普通扫描、真实威胁和拒绝服务类高危事件。该过程若与资产管理、补丁管理和应急响应联动，可形成更完整的设备级安全闭环。

八、结论

综上，原论文提出的高安全属性价值设备威胁态势量化评估方法，将网络安全态势评估从宏观网络层推进到关键设备层。它通过安全属性价值识别重点设备，通过配置、脆弱性和性能验证有效告警，通过状态评估描述攻击阶段，通过 ETSA 公式计算威胁态势值。该方法能够较好解释关键设备在扫描、攻击和拒绝服务场景下的安全状态变化，是网络安全态势感知体系中的重要微观补充。对于关键基础设施、政务专网、金融网络和数据中心安全运维而言，面向高价值设备的量化评估具有现实意义。

参考文献

- [1] 韩磊, 刘吉强, 王健, 等. 高安全属性价值设备威胁态势量化评估方法[J]. 网络与信息安全学报, 2020, 6(5): 54-66.
- [2] 龚正虎, 卓莹. 网络态势感知研究[J]. 软件学报, 2010, 21(7): 1605-1619.
- [3] Endsley M. Situation awareness global assessment technique, 1988.
- [4] 国家信息中心. GB/T 20984-2007 信息安全技术信息安全风险评估规范[S]. 北京: 中国标准出版社, 2007.
- [5] CVSS. Common Vulnerability Scoring System.